

MITIGATIONS AND HARDENING IMPLEMENTATIONS

Each finding was traced end-to-end from bug class (OWASP Top 10, 2025) through adversary technique (MITRE ATT&CK) to the specific control applied, so the connection between vulnerability, exploitation, and fix is explicit rather than treated as three separate exercises.

Finding	OWASP Category (2025)	ATT&CK	Control Applied	Residual Risk
Unpatched SMB / Samba Badlock	A03: Software Supply Chain Failures	T1190	Patch/upgrade Samba, disable legacy protocol negotiation, restrict SMB to trusted hosts.	Low
UnrealIRCd / bind-shell backdoors	A02: Security Misconfiguration	T1190	Remove backdoored packages/binaries, patch, firewall the affected ports.	Low
VNC weak password	A07: Authentication Failures	T1110	Enforce a strong password, disable VNC or restrict access to a VPN/jump host.	Low
NFS world-readable export	A01: Broken Access Control	T1046	Restrict NFS exports to specific hosts and require authentication.	Low
SSLv2/v3 & SWEET32 weak ciphers	A02: Security Misconfiguration	T1040	Disable SSLv2/v3, remove medium-strength ciphers, enforce TLS 1.2+.	Low
Ubuntu / Tomcat SEoL	A03: Software Supply Chain Failures	T1190	Upgrade to a supported OS/application release with an active patch cycle.	Medium
rlogin trust-based auth	A07: Authentication Failures	T1110	Disable rlogin/rsh; require SSH with key-based authentication instead.	Low